

CSE 331: Computer Security Fundamentals

Spring 2026

Network Security:
Domain Name Service (DNS)

Amir Rahmati
Xinrui Yu



Stony Brook Institute
at Anhui University

安徽大学纽约石溪学院

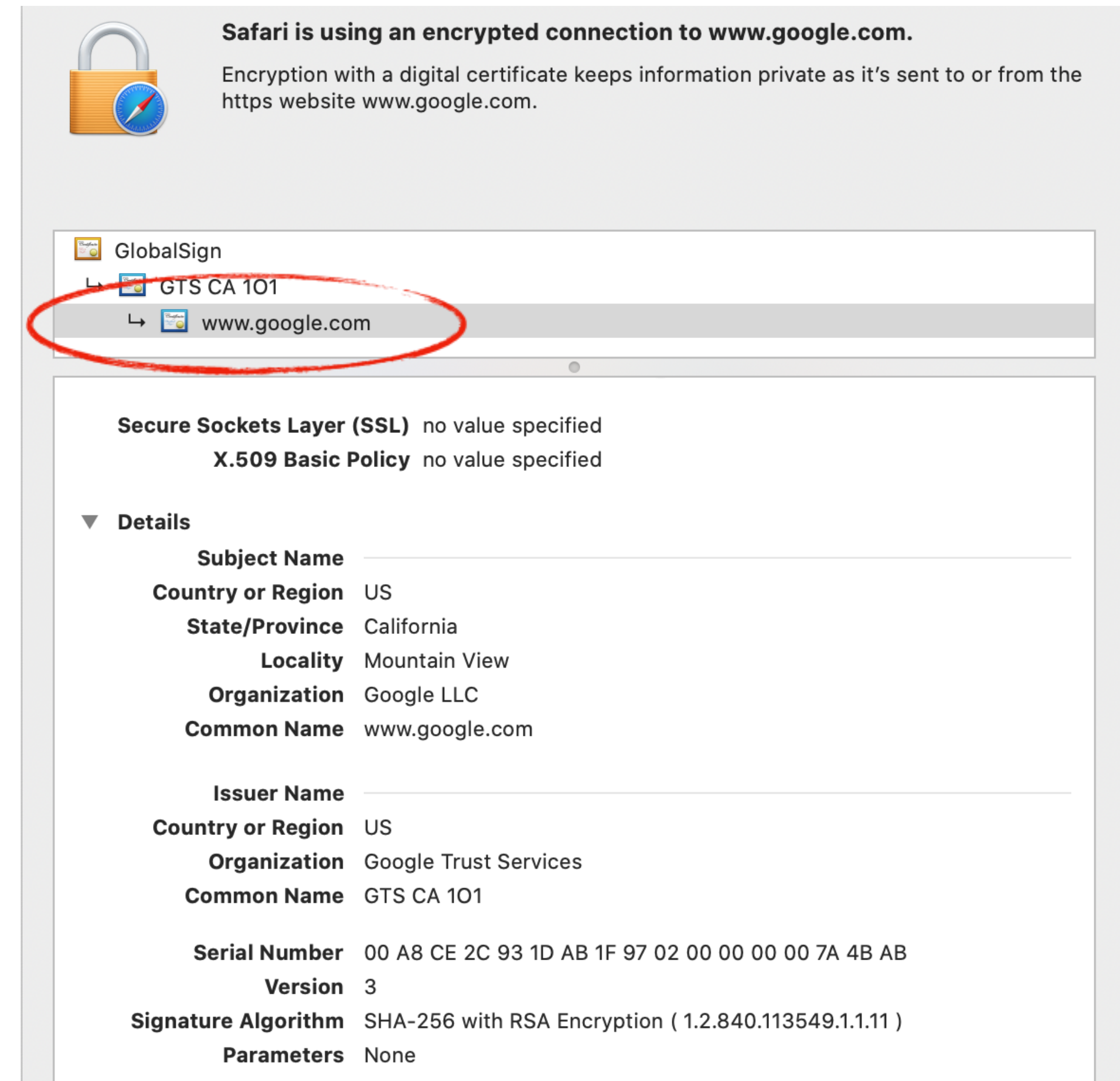
Remember Certificates?

- Problem 1: How to go from the common name to IP?

DNS

- Problem 2: How to find the correct route to reach the IP?

BGP



Domain Name Service (DNS)

Mapping from domain names to IP addresses

No encryption for best performance

No authentication for best performance

```
$nslookup cs.stonybrook.edu
```

```
Server:      8.8.8.8
```

```
Address: 8.8.8.8#53
```

```
Non-authoritative answer:
```

```
Name: cs.stonybrook.edu
```

```
Address: 130.245.27.3
```

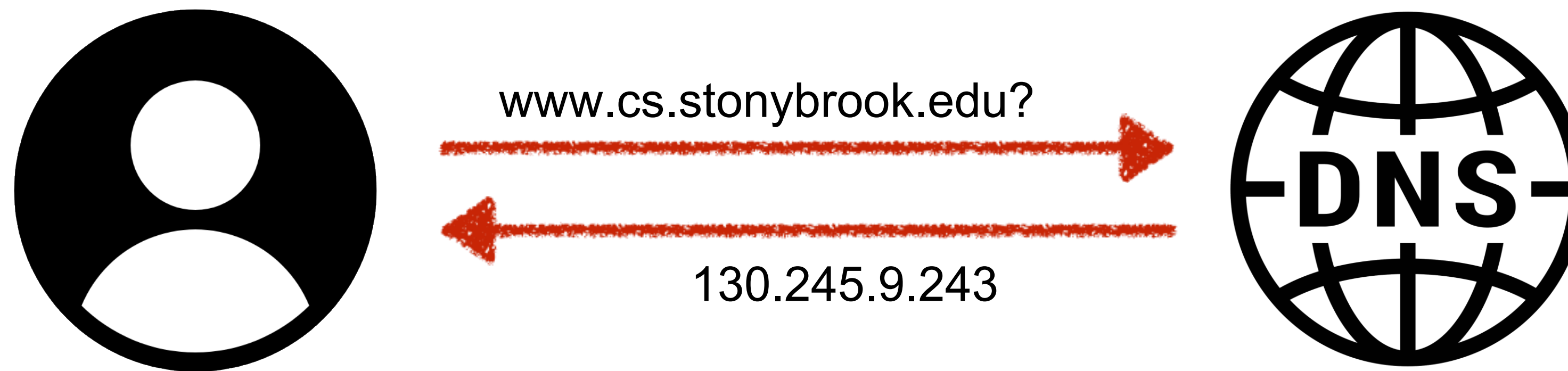
host.txt still exists

```
$cat /etc/hosts
##
# Host Database
#
# localhost is used to configure the
# loopback interface
# when the system is booting.  Do not
# change this entry.
##
127.0.0.1    localhost
255.255.255.255    broadcasthost
::1         localhost
```

Early days of ARPANET:

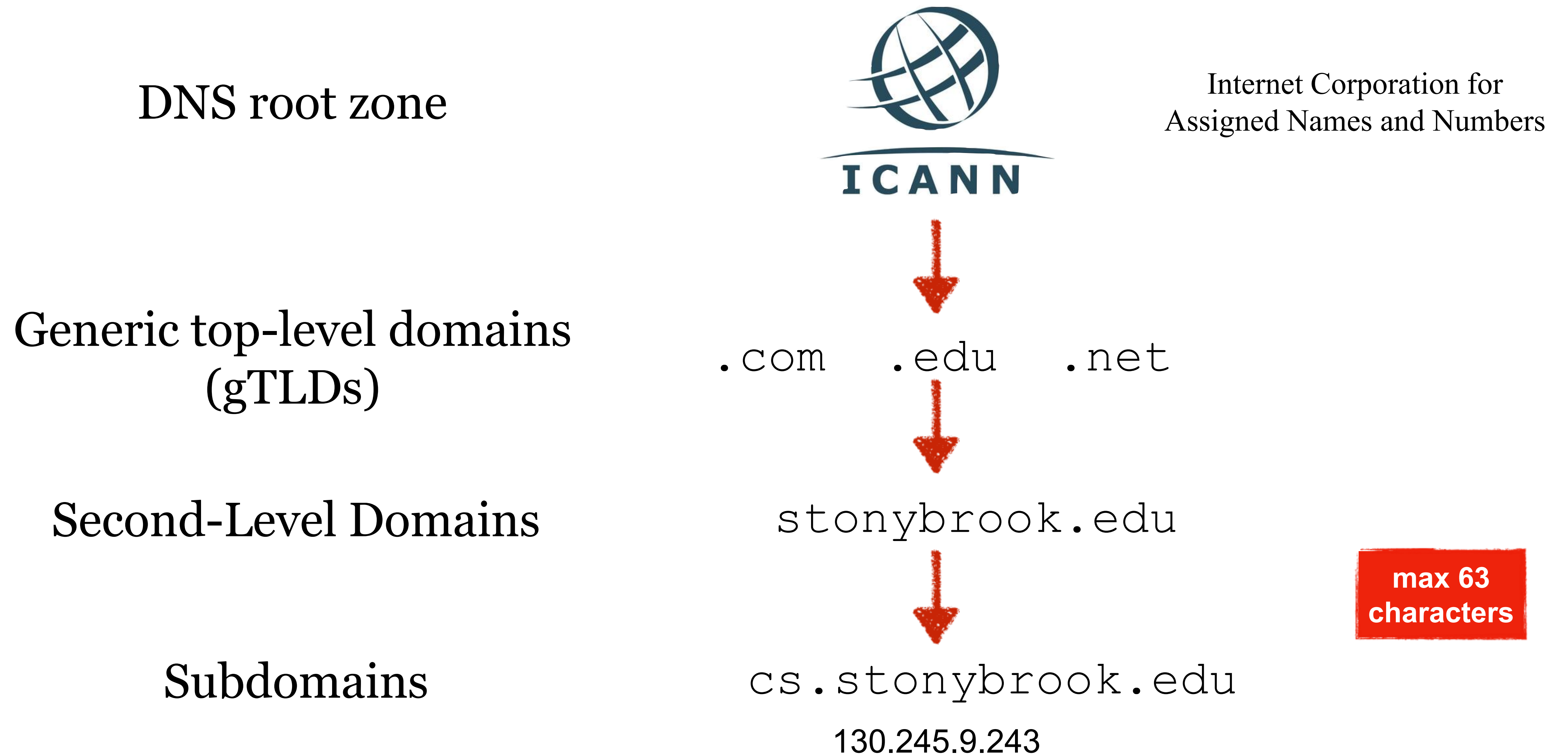
manually managed `hosts.txt`
served from single computer at SRI

Domain Name System



- Distributed, hierarchical, reliable database
- Not always one-to-one:
 - Virtual Hosting: Many names —> Single IP
 - Load Balancing/Fault Tolerance: Single name —> Many IPs

DNS Server Hierarchy



Types of DNS servers

- **DNS Resolvers:** /etc/hosts.txt, ...
- **Root Nameservers:** 13 of them in total.
 - E.g. Verisign controls .com
- **Authoritative Nameservers:** authorized to provide IP for a (sub)domain / hostname
 - Zone: a contiguous portion of domain namespace (a subtree)

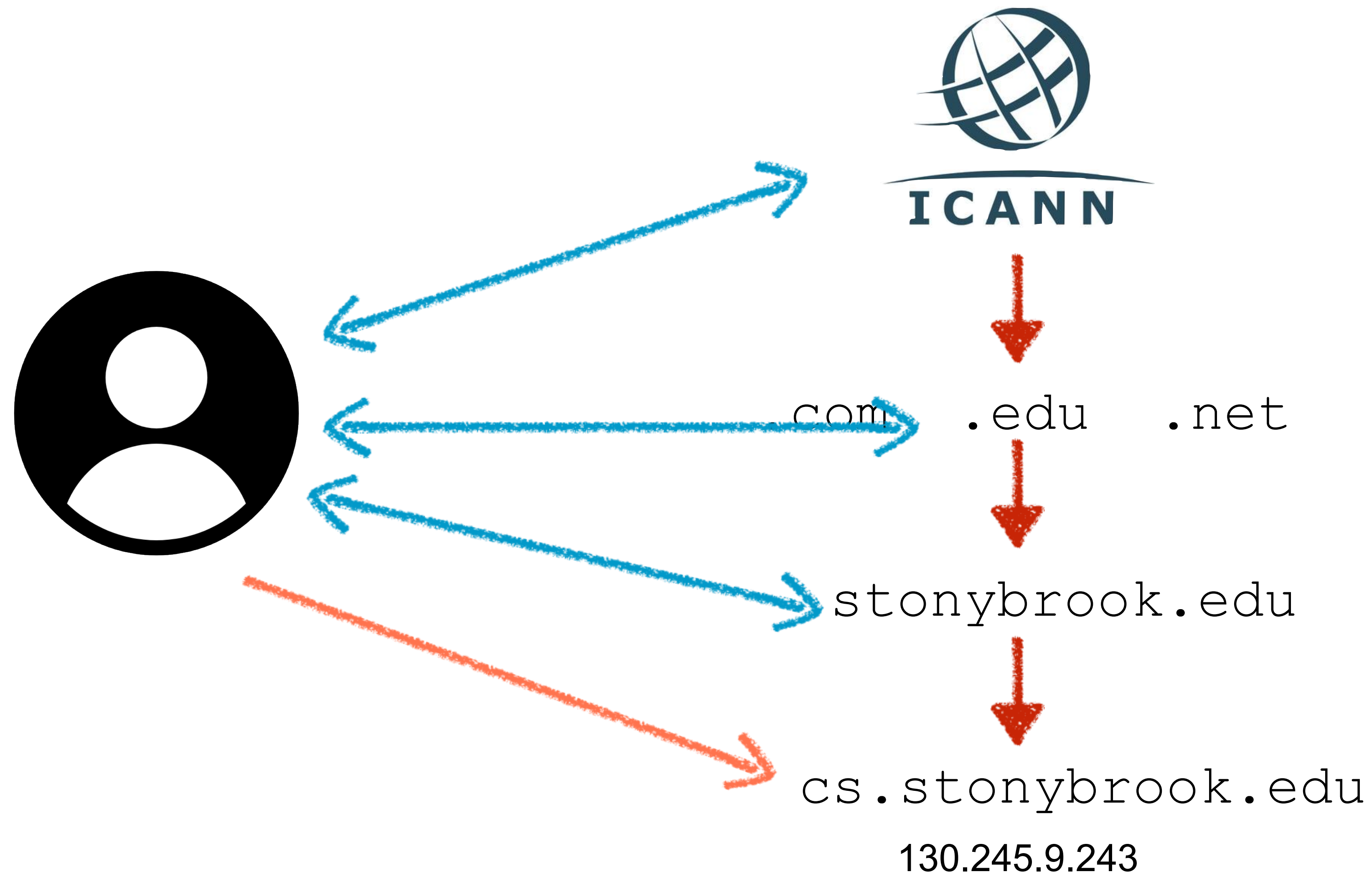
HOSTNAME	IP ADDRESSES	OPERATOR
a.root-servers.net	198.41.0.4, 2001:503:ba3e::2:30	Verisign, Inc.
b.root-servers.net	199.9.14.201, 2001:500:200::b	University of Southern California, Information Sciences Institute
c.root-servers.net	192.33.4.12, 2001:500:2::c	Cogent Communications
d.root-servers.net	199.7.91.13, 2001:500:2d::d	University of Maryland
e.root-servers.net	192.203.230.10, 2001:500:a8::e	NASA (Ames Research Center)
f.root-servers.net	192.5.5.241, 2001:500:2f::f	Internet Systems Consortium, Inc.
g.root-servers.net	192.112.36.4, 2001:500:12::d0d	US Department of Defense (NIC)
h.root-servers.net	198.97.190.53, 2001:500:1::53	US Army (Research Lab)
i.root-servers.net	192.36.148.17, 2001:7fe::53	Netnod
j.root-servers.net	192.58.128.30, 2001:503:c27::2:30	Verisign, Inc.
k.root-servers.net	193.0.14.129, 2001:7fd::1	RIPE NCC
l.root-servers.net	199.7.83.42, 2001:500:9f::42	ICANN
m.root-servers.net	202.12.27.33, 2001:dc3::35	WIDE Project

Root nameservers

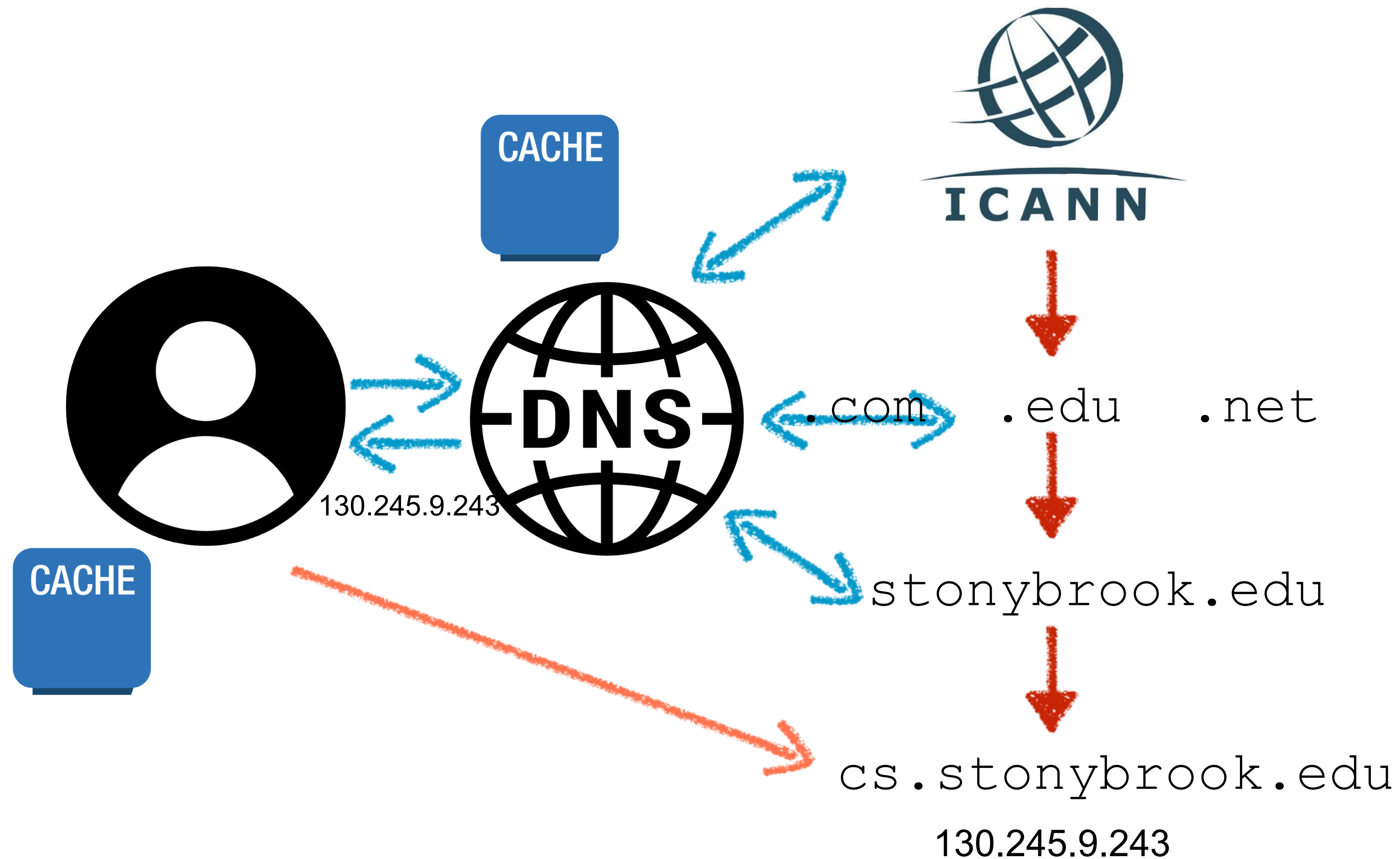
- 13 of them (A-M) in total.



DNS Resolution - Iterative



DNS Resolution - Recursive



Example DNS record (and query) types

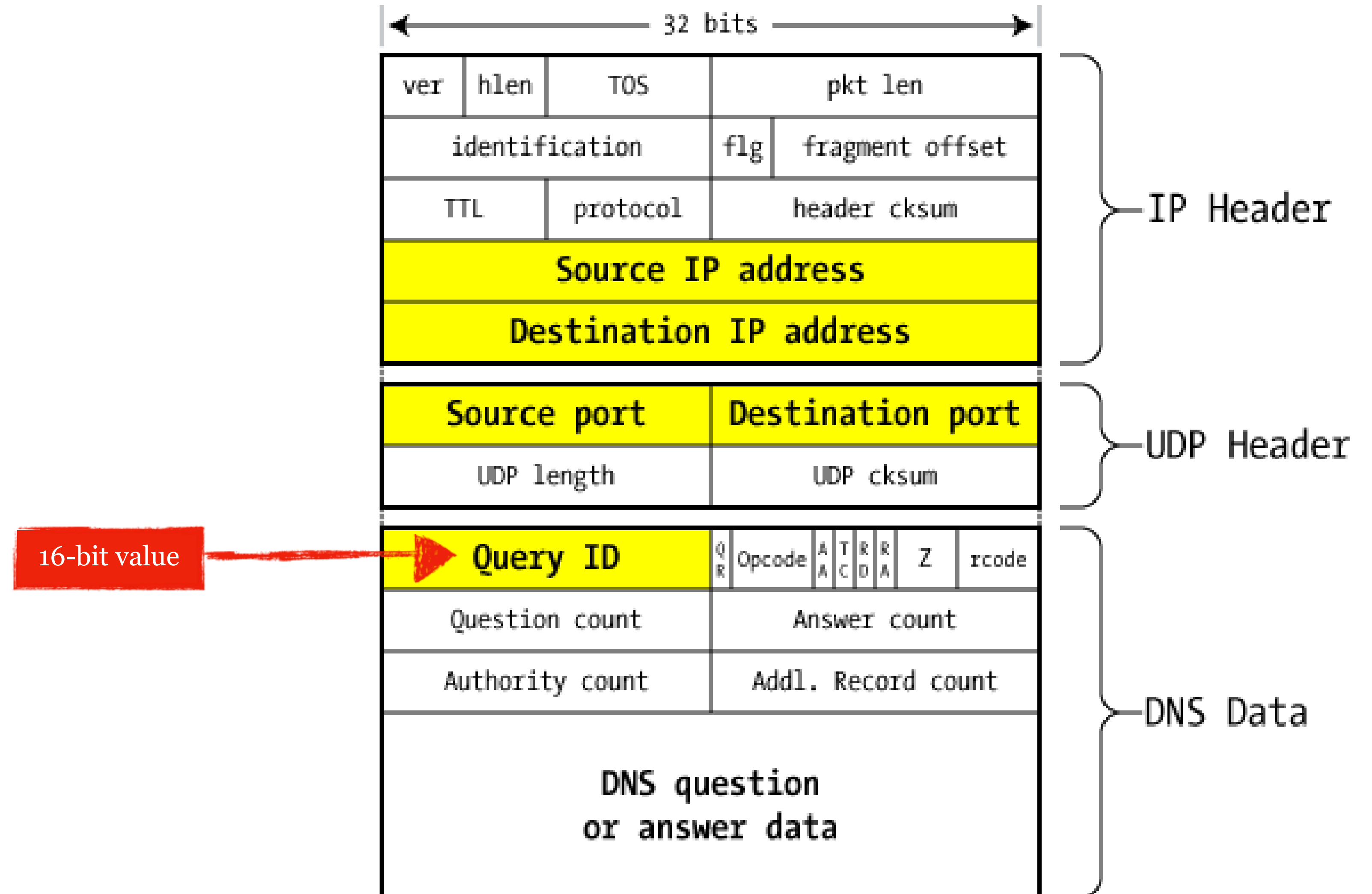
A	Address mapping record (get me an IPv4 address)
AAAA	Same for IPv6 address
NS	name server, the DNS zone
TXT	machine readable text data, has been used for many things, including encryption mechanisms, policy
MX	mail exchange (SMTP mail server for the domain)
CNAME	Canonical name, alias of a domain

Bailiwick check

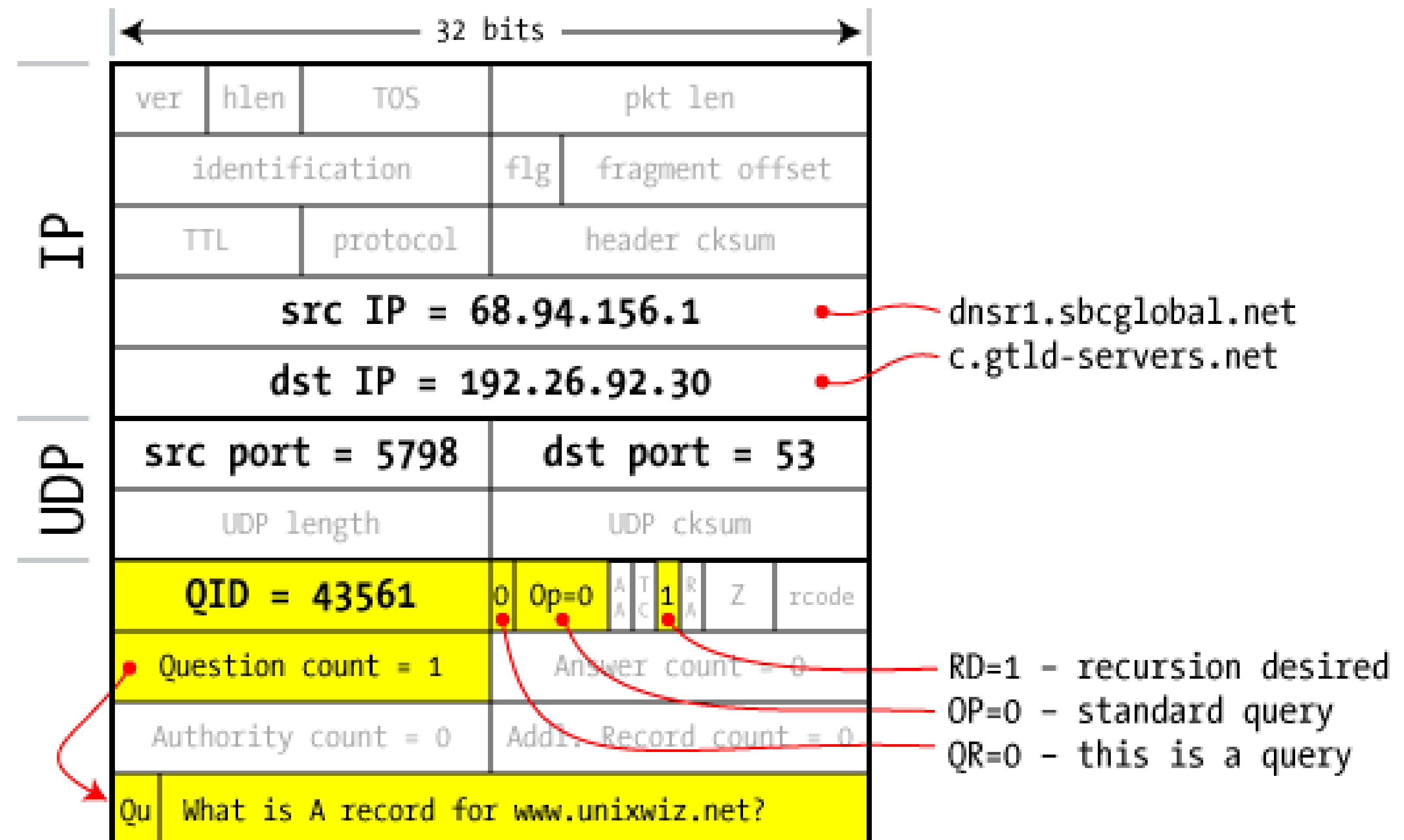
response is cached if it is within the same domain of query
i.e. ns.a.com cannot set NS for b.com

DNS packet on wire

www.unixwiz.net

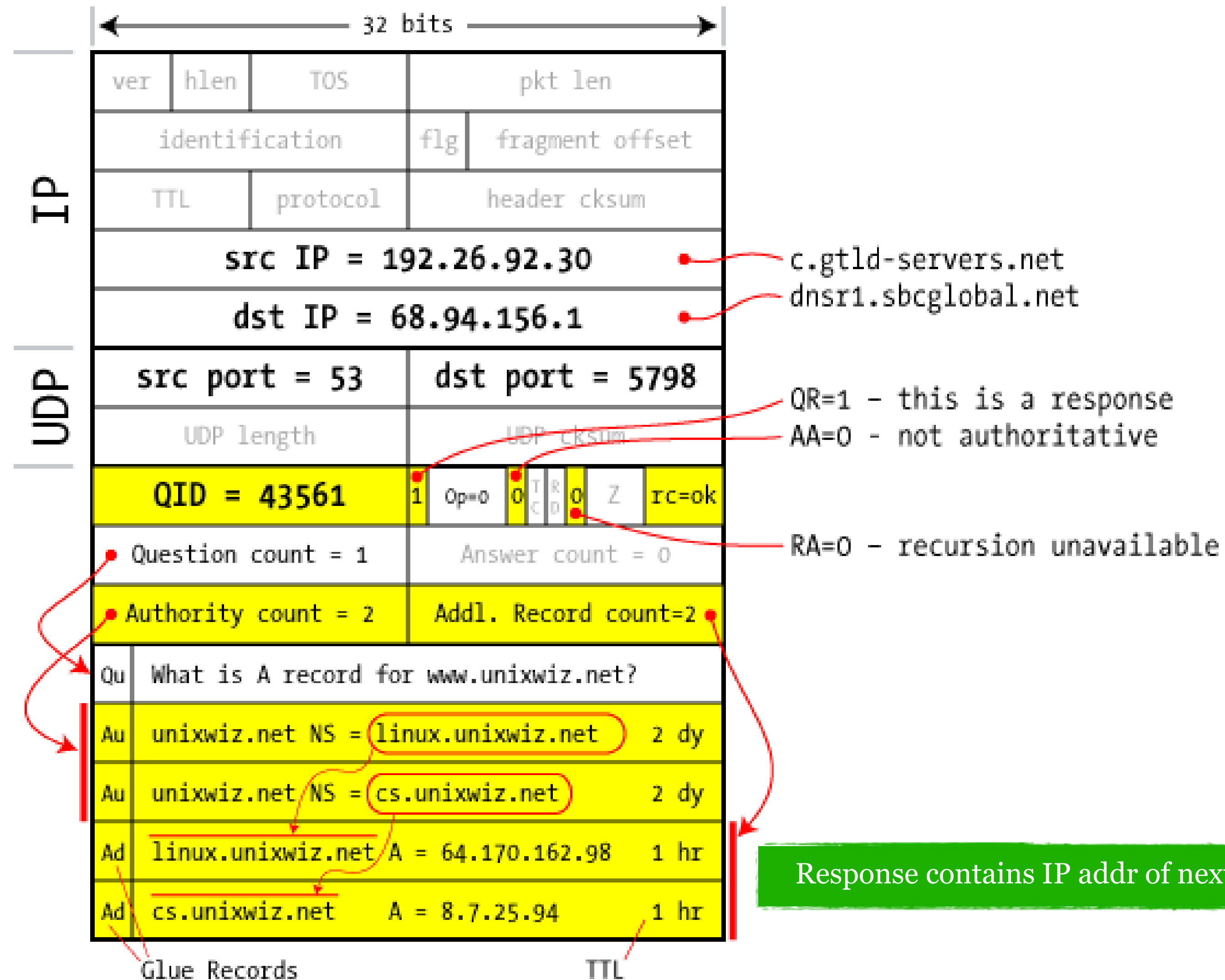


Query from resolver to NS

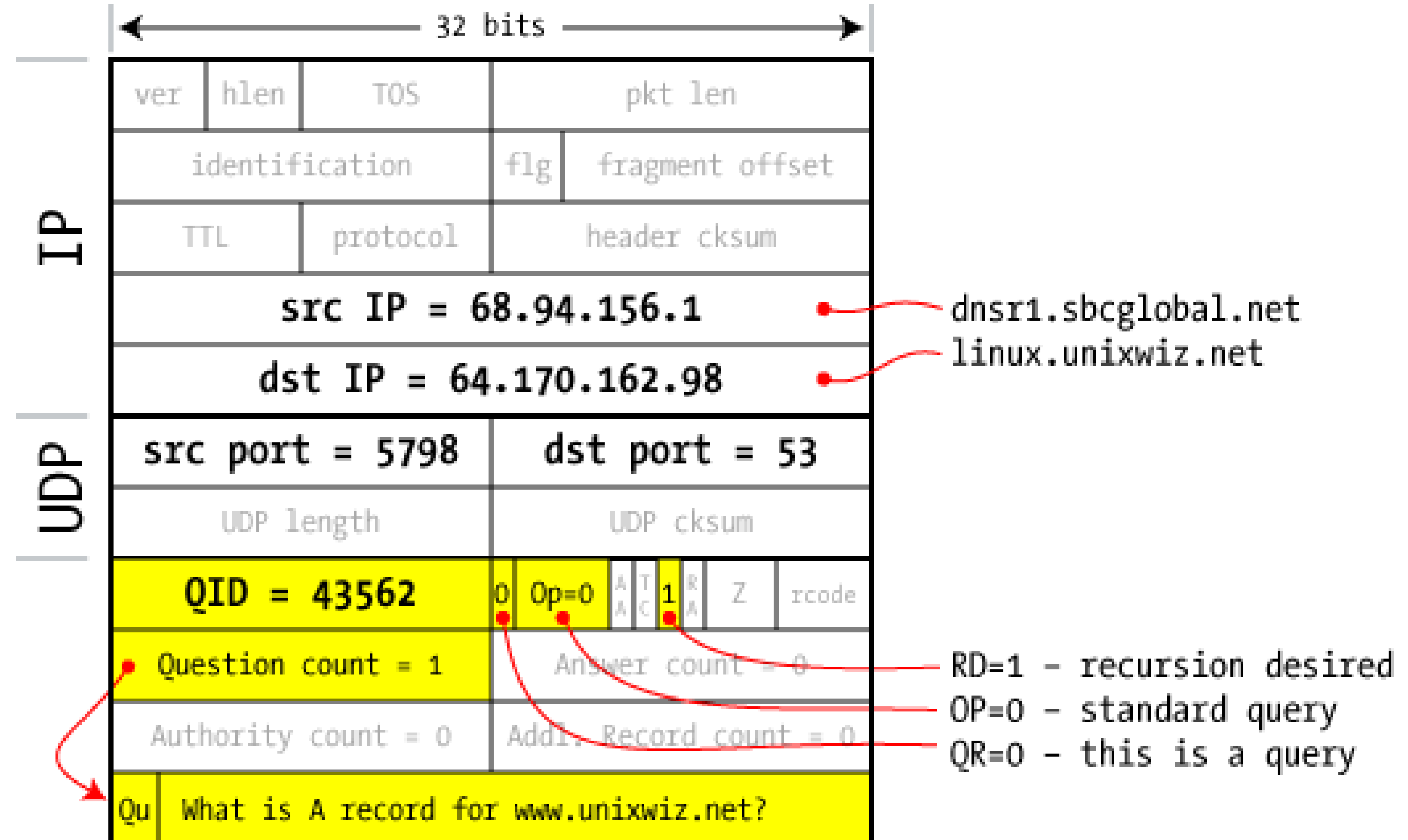


Reply from NS to Resolver

Response ignored if unrecognized QueryID



Query to Second NS



Reply from Second NS to Resolver

		← 32 bits →											
IP	ver	hlen	TOS		pkt len								
	identification				flg	fragment offset							
	TTL		protocol		header cksum								
	src IP = 64.170.162.98										linux.unixwiz.net		
	dst IP = 68.94.156.1										dnsr1.sbcglobal.net		
UDP	src port = 53					dst port = 5798							
	UDP length					UDP cksum							
	QID = 43562					1	Op=0	1	T	R	Z	rc=ok	
	Question count = 1					Answer count = 1					RA=0 - recursion unavailable		
	Authority count = 2					Addl. Record count=2							
	Qu	What is A record for www.unixwiz.net?											
	An	www.unixwiz.net A = 8.7.25.94 1 hr											
	Au	unixwiz.net NS = linux.unixwiz.net 2 dy											
	Au	unixwiz.net NS = cs.unixwiz.net 2 dy											
	Ad	linux.unixwiz.net A = 64.170.162.98 1 hr											
	Ad	cs.unixwiz.net A = 8.7.25.94 1 hr											

Where was the security again?

- What security checks are in place?
 - Query ID's (A.K.A. TXID) to link responses to queries
 - Bailiwick check (sanity check on response)
- No authentication
- No confidentiality
 - Does it matter?
- Many things trust hostname to IP mapping
 - Browser same-origin policy
 - URL address bar

DDoS against DNS

- Denial of Service
 - take down DNS server, clients can't use Internet
 - Attack against root servers

Massive DDoS Attack Hit DNS Root Servers

By Ryan Naraine,

Posted October 23, 2002

Data Centre ► **Networks**

Internet's root servers take hit in DDoS attack

Who's testing the limits of the DNS system?

By Kieren McCarthy in San Francisco 8 Dec 2015 at 23:10

27 

SHARE ▼

PCWorld
FROM IDG

SUBSCRIBE



Start Searching

NEWS REVIEWS HOW-TO VIDEO DEALS ▼ BUSINESS LAPTOPS SMARTPHONES HARDWARE SECURITY SOFTWARE GADGETS ▼

[Home](#)

UPDATED

Major DDoS attack on Dyn DNS knocks Spotify, Twitter, Github, PayPal, and more offline

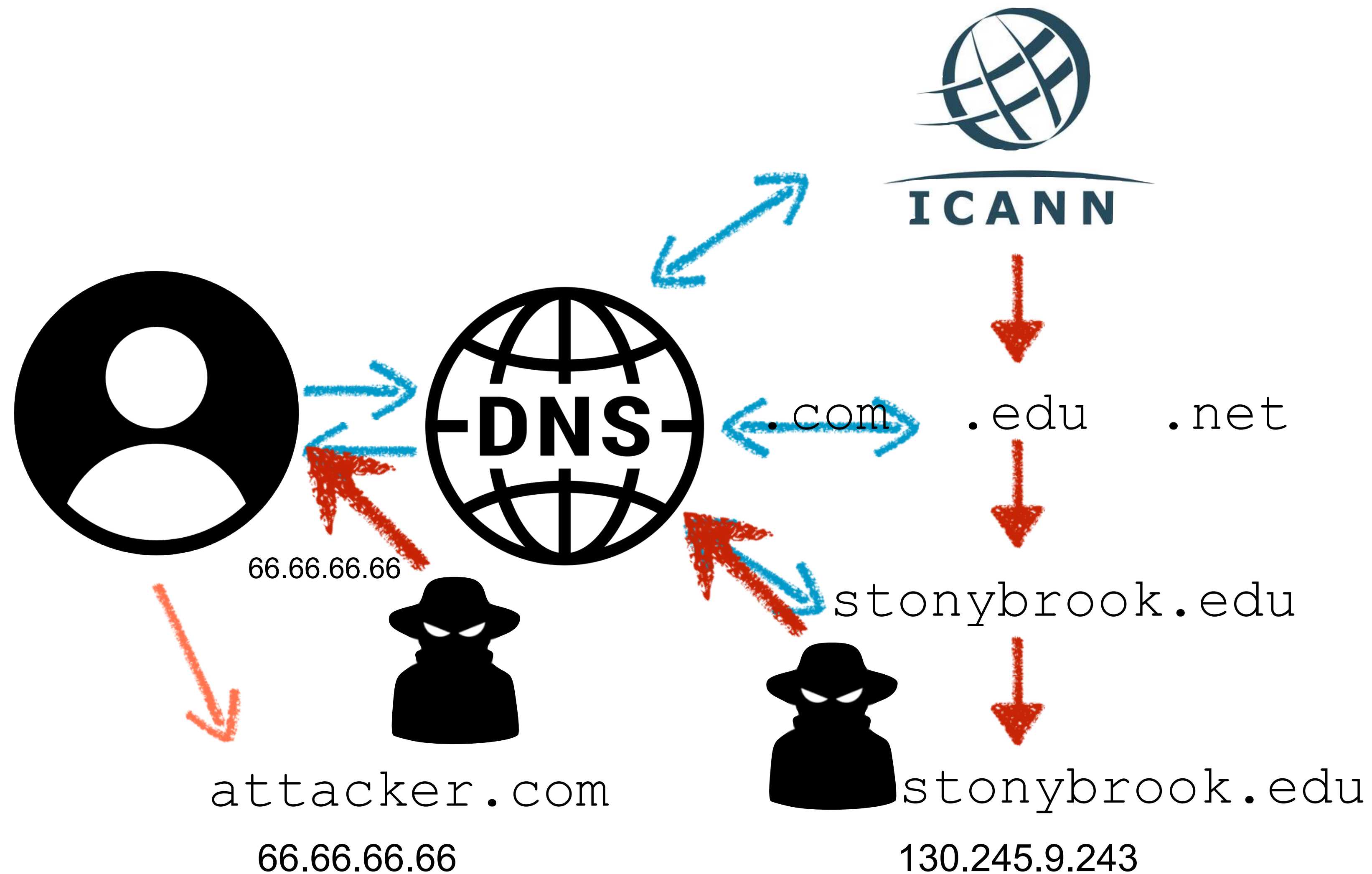
The sound of silence.



By **Brad Chacos**

Senior Editor, PCWorld | OCT 21, 2016 3:34 PM PDT

DNS Spoofing/Cache Poisoning



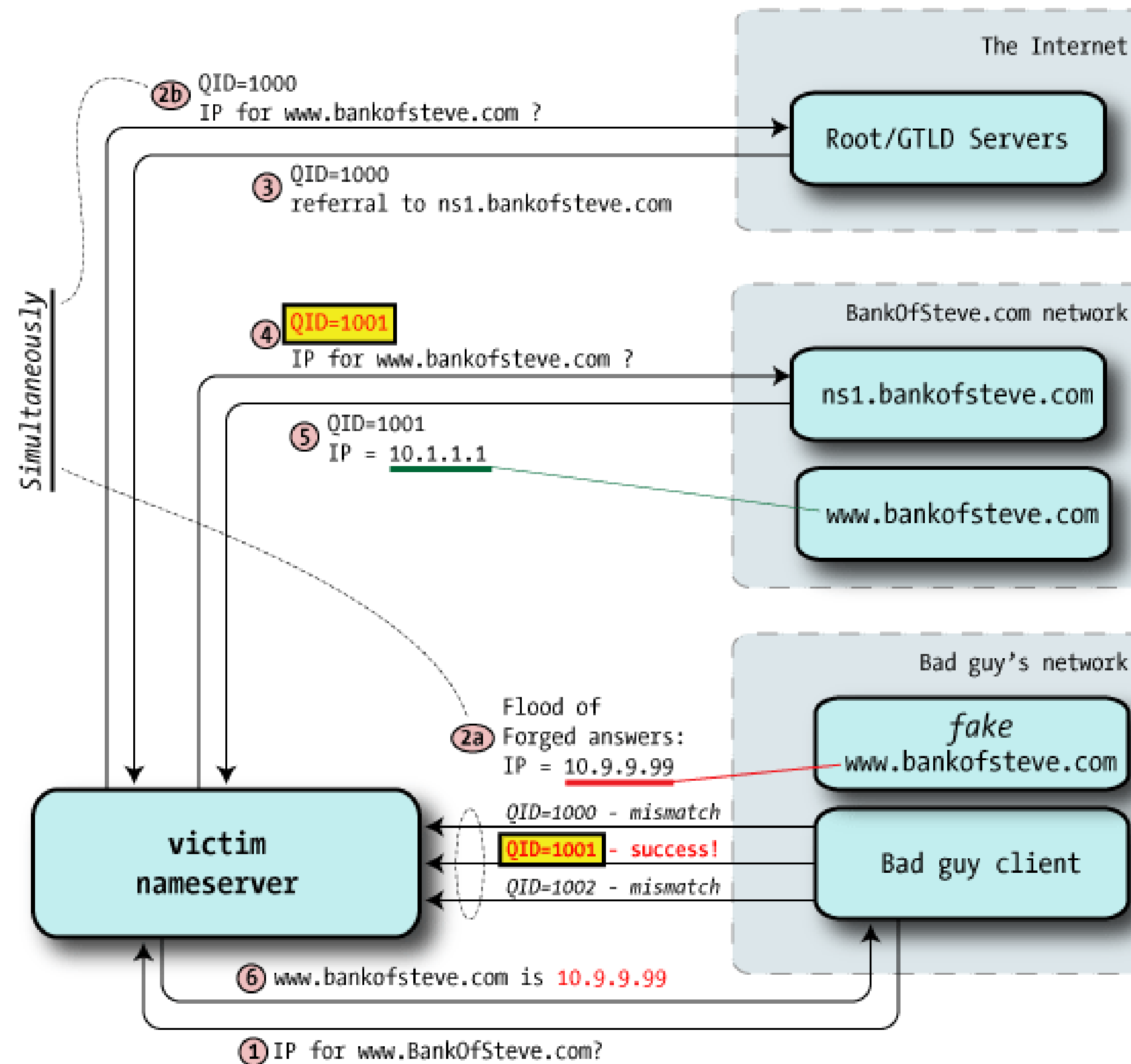
Vantage Points

- **Off-path:** attackers cannot observe any DNS queries and responses (blind)
 - Blind packet injection: must guess the proper values in the response fields according to the query
 - Race condition: forged response must arrive before the real one
- **On-path:** attackers can passively observe the traffic (queries) and inject properly forged responses (MotS)
 - Easy to mount in WiFi networks, by ISPs, ...
 - Race condition: forged response must arrive before the real one
- **In-path:** attackers can block responses from reaching the victim, and inject forged ones instead (MitM)
 - But then the attacker can do so much more...

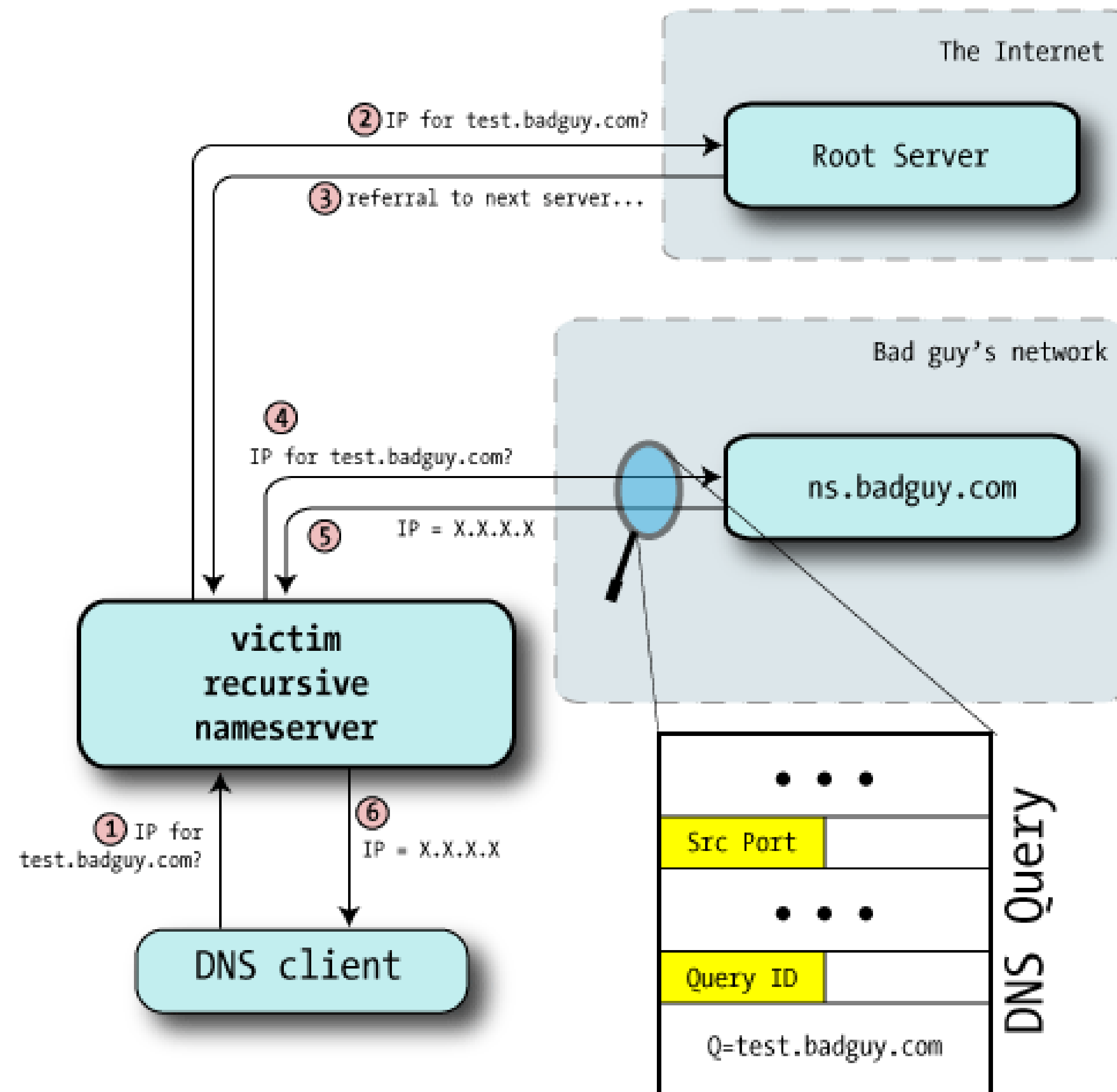
Attacker's Goal

- Matching source and destination IP address
- Matching source and destination UDP port
 - old DNS servers would use 53 for source port (even if different, can be easily inferred)
- Matching Query ID
 - 16 bits of randomness
- Matching question section
 - attacker targets a particular recursive server, so can trigger a query at will

If the record doesn't exist



How to predict the query ID?



What if the record exist?

Kaminsky Attack (2008)

- Query the recursive with any subdomain not in the cache
 - Non-existent subdomains are fine: foo1.example.com
 - Not affected by TTL (e.g., as would be the case for www.example.com)
 - Causes the target resolver to query the authoritative server(s) for the requested subdomain
- The attacker then floods the resolver with a large number of forged responses
 - Each containing a different guess of the query's TXID

Fake referral →

```
;; ANSWER SECTION:
foo1.example.com.      120   IN A   10.0.0.10
;; AUTHORITY SECTION:
example.com.           86400 IN NS
ns1.example.com.
;; ADDITIONAL SECTION:
ns1.example.com.       604800 IN A   10.6.6.6
```

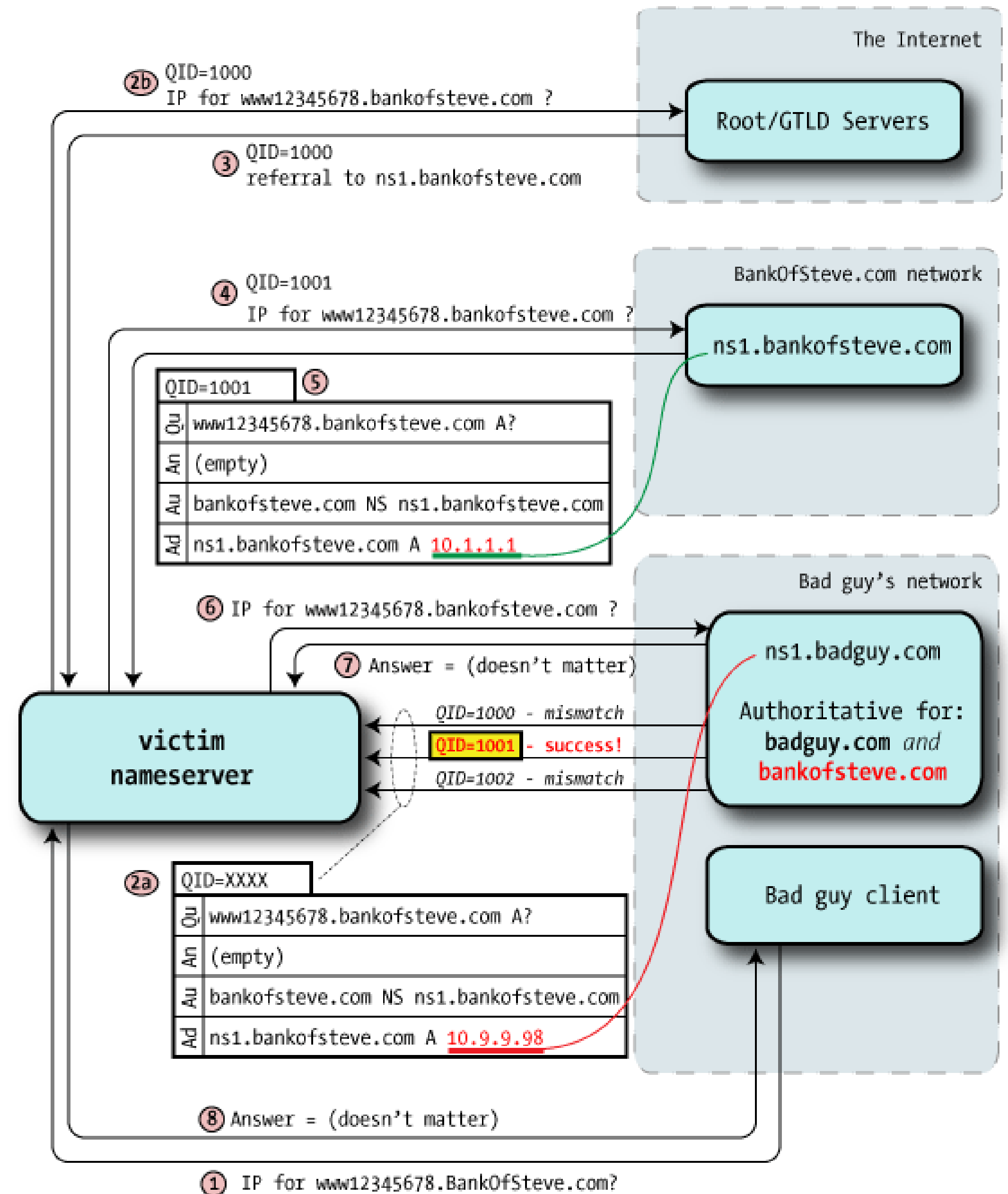
- If the race is lost, just repeat with a different subdomain!

Kaminsky Attack

- Poison cache for NS record instead
- Now can take over all of second level domain

How many tries does this require?

- 16 bit query id field
- If choosing randomly: 256 (birthday paradox!)
- If predictable, choose in range



Normal DNS Query

Cache:
A www.example.com
104.18.27.120
NS _.example.com
172.64.32.228

Local DNS Server
10.9.0.53

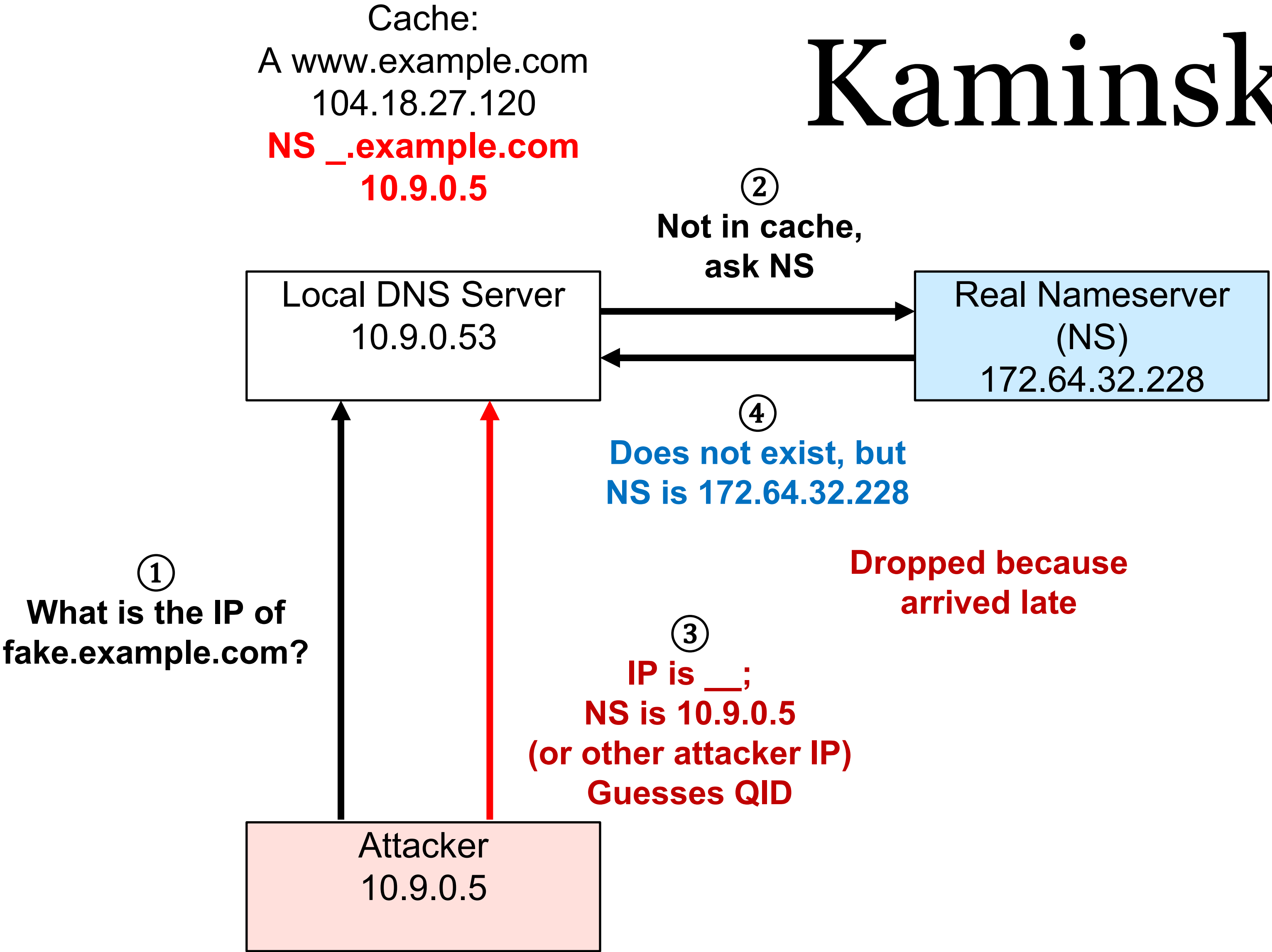
①
What is the A record
(IPv4 address) of
www.example.com?

②
104.18.27.120
(in cache, no need to ask)

User



Kaminsky Attack



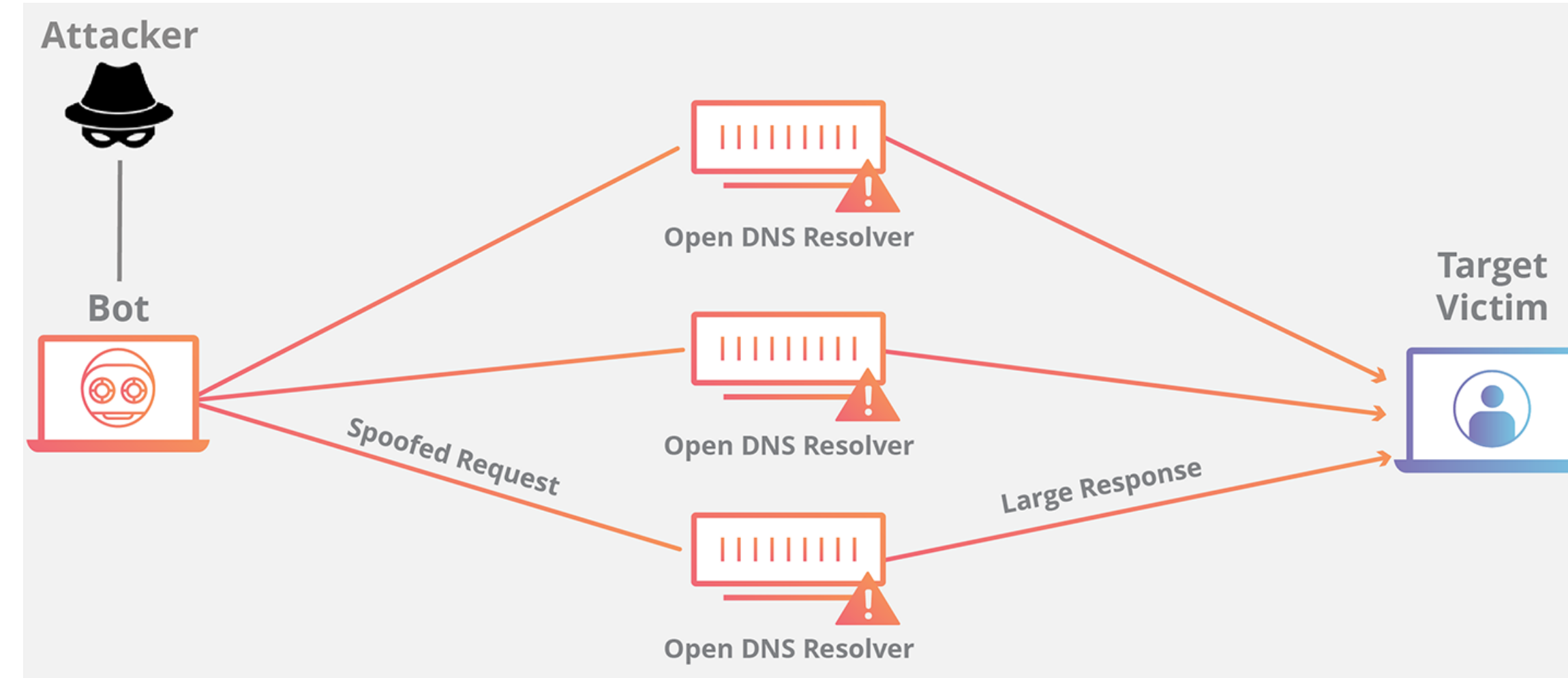
How to fix this?

- TXID randomization
- Port randomization
- DNSSec

Cryptographically sign DNS responses, verify
via chain of trust from roots on down

... but DNSSec vulnerable to DDoS

- Create large amount traffic from the DNS resolvers to the victim computer/server



Help Net Security
September 18, 2019

Share



DNSSEC fueling new wave of DNS amplification attacks

DNS amplification attacks swelled in the second quarter of this year, with the amplified attacks spiking more than 1,000% compared with Q2 2018, according to Nexusguard.

Phishing is common problem

- Typo squatting:

- www.qpple.com
- www.goggle.com
- www.nytmes.com

- Other shenanigans:

- [www.badguy.com/\(256 characters of filler\)/www.google.com](http://www.badguy.com/(256%20characters%20of%20filler)/www.google.com)

- Phishing attacks

- These just trick users into thinking a malicious domain name is the real one

Pharming

- Mostly traffic redirection attacks at the client side
- **Local pharming**
 - Malware can alter local DNS settings
 - Change the system's (or the local router's) DNS server
 - Add entries in /etc/hosts
- **Drive-by pharming**
 - A malicious web page contains JavaScript code that alters the local router's DNS server from the inside LAN
- **Dynamic pharming (2007)**
 - Quickly switch mapping of bank.com between a malicious and a real IP
 - First serve malicious script, then switch to the real site -> same origin policy is bypassed

- **/etc/hosts**

IPAddress

Hostname

130.245.9.243

cs.stonybrook.edu

DoH (DNS over HTTPS)

- Standard DNS is plain text!
- DoH blends DNS queries into standard web traffic.

Layered Security:

- **Standard DNS:** [Ethernet][IP][UDP][DNS Query]
- **DoH:** [Ethernet][IP][TCP][TLS][HTTP/2][DNS Query]